

Practical

Issues Detected by Bandit

Copilot finding	Bandit detected it?	Bandit ID and line	Explanation	Secure remediation
Importing <code>pickle</code>	Yes	B403 , line 2	Bandit flags the <code>pickle</code> import because it can enable unsafe deserialization when used with untrusted data.	Avoid <code>pickle</code> for untrusted data; use JSON or another safe, validated format.
Importing <code>subprocess</code>	Yes	B404 , line 3	Bandit flags the module because unsafe subprocess usage can lead to command execution vulnerabilities. The import itself does not prove exploitation.	Prefer avoiding subprocesses; otherwise use fixed commands, argument lists, validation, and no shell.
Hardcoded password	Yes	B105 , line 5	<code>admin123</code> is embedded directly in source code, allowing anyone with source access to obtain it.	Use a secret manager or protected environment variable and rotate the exposed password.
Weak MD5 password hashing	Yes	B324 , line 10	MD5 is unsuitable for password hashing because it is fast and vulnerable to brute-force attacks.	Use Argon2id, scrypt, or bcrypt with a unique salt.
Shell command injection	Yes	B602 , line 14	User input is passed to <code>subprocess.call</code> with <code>shell=True</code> , allowing shell syntax to be interpreted.	Remove <code>shell=True</code> , use a fixed executable with an argument list, and validate inputs.
Unsafe pickle deserialization	Yes	B301 , line 18	<code>pickle.loads</code> can execute attacker-controlled code during deserialization.	Never deserialize untrusted pickle data; use a safe format such as JSON with validation.
SQL injection	Yes	B608 , line 22	<code>username</code> is concatenated directly into the SQL query, allowing query manipulation. Bandit reported low confidence for this finding.	Use parameterized queries or prepared statements.

Issues Identified by Copilot but Not Detected by Bandit

Copilot finding	Bandit detected it?	Bandit ID and line	Explanation	Secure remediation
Hardcoded API key	No	No Bandit finding or reported line	<code>API_KEY = "12345-SECRET-KEY"</code> appears in source at <code>app.py</code> line 6. Bandit's B105 finding covered only the password on line 5, not this API key.	Remove the key from source, store it in a secret manager or protected environment variable, and rotate it.
Debug mode enabled	No	No Bandit finding or reported line	<code>DEBUG = True</code> appears at <code>app.py</code> line 21. If used by the surrounding application, production debug behavior could expose sensitive error details or debugging functionality. This file alone does not show how the flag is used.	Disable debug mode in production and make it controlled by a secure deployment configuration.

```

Code scanned:
  Total lines of code: 16
  Total lines skipped (#nosec): 0
  Total potential issues skipped due to specifically being disabled (e.
g., #nosec BXXX): 0

Run metrics:
  Total issues (by severity):
    Undefined: 0
    Low: 3
    Medium: 2
    High: 2
  Total issues (by confidence):
    Undefined: 0
    Low: 1
    Medium: 1
    High: 5
Files skipped (0):
PS C:\Users\ycce\Downloads\IT_A>

```

Fix 1 :-

Original issue: B301/B403

Original lines: 2 and 18

Fix: Replaced unsafe pickle serialization/deserialization

with JSON

Verification: Re-ran Bandit

Result: B301/B403 no longer reported

```

Code scanned:
  Total lines of code: 16
  Total lines skipped (#nosec): 0

Run metrics:
  Total issues (by severity):
    Undefined: 0
    Low: 2
    Medium: 1
    High: 2
  Total issues (by confidence):
    Undefined: 0
    Low: 1
    Medium: 1
    High: 3
Files skipped (0):
PS C:\Users\ycce\Downloads\IT_A>

```

Fix 2 :-

Original issue: B404/B602

Original lines: 3 and 14

Fix: Removed subprocess with shell=True and
replaced it with non-shell process execution

Verification: Re-ran Bandit

Result: B404/B602 no longer reported; Bandit then reported
B606 for the remaining process-execution pattern

```

Run metrics:
  Total issues (by severity):
    Undefined: 0
    Low: 2
    Medium: 1
    High: 1
  Total issues (by confidence):
    Undefined: 0
    Low: 1
    Medium: 2
    High: 1
Files skipped (0):

```

Fix 3 :-

Original issue: B606

Original line: 16

Fix: Restricted process execution so user input cannot directly
determine an arbitrary operating-system command

Verification: Re-ran Bandit

Result: B606 no longer reported

```

Run metrics:
  Total issues (by severity):
    Undefined: 0
    Low: 1
    Medium: 1
    High: 1
  Total issues (by confidence):
    Undefined: 0
    Low: 1
    Medium: 1
    High: 1
Files skipped (0):

```

Fix 4 :-

Original issue: B105

Original line: 6

Fix: Removed the hardcoded password and changed the application to obtain the password from an environment variable

Verification: Re-ran Bandit

Result: B105 no longer reported

Fix 5 :-

Original issue: B608

Original line: 27

Fix: Replaced the SQL query's string concatenation with a parameterized query to prevent SQL injection.

Verification: Re-ran Bandit

Result: B608 no longer reported.

```
Run metrics:
  Total issues (by severity):
    Undefined: 0
    Low: 0
    Medium: 1
    High: 1
  Total issues (by confidence):
    Undefined: 0
    Low: 1
    Medium: 0
    High: 1
Files skipped (0):
```

```
Run started Press 'Enter' to confirm your input or 'Escape' to cancel

Test results:
>> Issue: [B324:hashlib] Use of weak MD5 hash for security.
Consider usedforsecurity=False
  Severity: High  Confidence: High
  CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
  More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324\_hashlib.html
  Location: .\app.py:10:11
9     def hash_password(password):
10         return hashlib.md5(password.encode()).hexdigest(
11     )

-----

Code scanned:
  Total lines of code: 21
  Total lines skipped (#nosec): 0

Run metrics:
  Total issues (by severity):
    Undefined: 0
    Low: 0
    Medium: 0
    High: 1
  Total issues (by confidence):
    Undefined: 0
    Low: 0
    Medium: 0
    High: 1
Files skipped (0):
```

Fix 6 :-

Original issue: Debug mode enabled (DEBUG = True)

Original line: 21

Fix: Changed the hardcoded debug setting to an environment-controlled configuration with debug disabled by default.

Verification: Re-ran Bandit

Result: No Bandit finding was generated for the debug configuration;
the issue was remediated manually

```
Test results:
  No issues identified.

Code scanned:
  Total lines of code: 26
  Total lines skipped (#nosec): 0

Run metrics:
  Total issues (by severity):
    Undefined: 0
    Low: 0
    Medium: 0
    High: 0
  Total issues (by confidence):
    Undefined: 0
    Low: 0
    Medium: 0
    High: 0
```

Fix 7 :-

Original issue: B324

Original line: 10

Fix: Replaced the insecure MD5 password hashing algorithm with

PBKDF2-HMAC-SHA256 using a unique random salt and a high iteration count.

Verification: Re-ran Bandit

Result: B324 no longer reported.

